

# People: who exists, and what they may be

---

Before this, HARI had no way to add a person. Across the whole application there were exactly two writes to the identity tables: a password reset, and the offboarding archive. Neither touched a role. Everyone in the demo existed because the seed script created them, and `employee:manage` — a permission whose own label reads *"Manage employee records"* — gated the offboarding pages and nothing else. The matrix advertised a capability the app did not have.

It has it now: `/people` is HR's admin for inviting, editing, re-roling and switching off accounts. This guide shows what each role can do there, and what the server refuses.

Every screenshot was taken from a running instance against the seeded demo data, signed in as the demo account named in the caption.

---

## The short version

|                               | Employee | Manager | HR Admin  | Super Admin |
|-------------------------------|----------|---------|-----------|-------------|
| Open <code>/people</code>     | no       | no      | yes       | yes         |
| Invite someone                | no       | no      | yes       | yes         |
| Change someone's role         | no       | no      | yes       | yes         |
| Assign <b>Super Admin</b>     | no       | no      | <b>no</b> | yes         |
| See and set salary            | no       | no      | yes       | yes         |
| Deactivate an account         | no       | no      | yes       | yes         |
| Edit their own name and photo | yes      | yes     | yes       | yes         |

The **no** in bold is the point of this guide, and the next section is about it.

---

## Managing people is not administering the platform

`/people` is gated on `employee:manage`; `/settings/roles` on `admin:settings`. HR holds the first and not the second. So HR decides **who is a Manager**; a Super Admin decides **what a Manager is**. Neither can do the other's job.

That split only means something because of one rule: **you can only assign a role whose permissions you hold yourself**. Without it, HR could put someone into Super Admin — or make a second account and put *themselves* there — and the separation would be a label on a door with no lock.

Open the role picker on the invite form and the two see different lists. This is a native select, so a screenshot cannot show it mid-drop; here is what it actually contains:

| Option                          | as HR Admin     | as Super Admin |
|---------------------------------|-----------------|----------------|
| Employee                        | selectable      | selectable     |
| Manager                         | selectable      | selectable     |
| HR Admin                        | selectable      | selectable     |
| <b>Super Admin</b>              | <b>disabled</b> | selectable     |
| Field Auditor ( <i>custom</i> ) | selectable      | selectable     |

A disabled option is invisible until you open the dropdown and silent even then, so the rule is stated under the field — HR is told why rather than left guessing:

**Role**

Employee

Some roles are greyed out: you can only assign a role whose permissions you hold yourself.

A Super Admin holds every permission, so nothing is greyed out and no note appears:

**Role**

Employee

The rule reads the live matrix, not a hierarchy, so it keeps working for roles that did not exist when it was written. *Field Auditor* — created in the [Roles guide](#) — holds four permissions HR already has, so HR may assign it freely. Add `admin:settings` to that same role and HR can no longer assign it, without anyone editing a list of "roles HR may grant".

## The roster

`/people`, as HR. Filters live in the URL and the form is a plain GET, so a filtered view is a link you can send someone.

*Invite pending* is a real state, not a guess: it means no password **and** no confirmed email, so the invite link is still the only way in. (Deriving it from "email not verified" would have flagged every seeded account, which have passwords and simply never used a magic link.)

 **HARI**  
HUMAN RESOURCES · AI

HR ADMIN WORKSPACE

Dashboard

AI Assistant

Directory

**People**

My Team

HR Activity

HR Analytics

Time Off

Onboarding

Offboarding

Documents

Knowledge Base

Alerts

Audit Log

NB

Nadia Benali

HR Admin

HARI / People

   

HR Admin

Invite person

Search by name or email

All roles

Active and deactivated

Filter

| Name                                                                       | Role     | Department                         | Status |
|----------------------------------------------------------------------------|----------|------------------------------------|--------|
| <div>AF</div> <div>Adil Fassi</div> <div>marketing.26@hari.ma</div>        | Employee | Growth Marketer · Marketing        | Active |
| <div>AS</div> <div>Adil Sekkat</div> <div>data.58@hari.ma</div>            | Employee | Data Analyst · Data                | Active |
| <div>AE</div> <div>Ahmed El marrouni</div> <div>a.elmarrouni@hari.ma</div> | Employee | Développeur Full stack · IT        | Active |
| <div>AM</div> <div>Amina Mansouri</div> <div>a.mansouri@hari.ma</div>      | Employee | Développeuse Frontend · IT         | Active |
| <div>AB</div> <div>Anas Benali</div> <div>people.40@hari.ma</div>          | Employee | HR Specialist · People             | Active |
| <div>AB</div> <div>Anas Bennis</div> <div>product.8@hari.ma</div>          | Employee | Product Analyst · Product          | Active |
| <div>AL</div> <div>Asmae Lahlou</div> <div>support.47@hari.ma</div>        | Employee | Support Specialist · Support       | Active |
| <div>AT</div> <div>Asmae Tazi</div> <div>design.15@hari.ma</div>           | Employee | Product Designer · Design          | Active |
| <div>AK</div> <div>Ayoub Kadiri</div> <div>operations.50@hari.ma</div>     | Employee | Logistics Coordinator · Operations | Active |
| <div>AS</div> <div>Ayoub Sekkat</div> <div>lead.sales@hari.ma</div>        | Manager  | Sales Manager · Sales              | Active |
| <div>BK</div> <div>Bilal Kadiri</div> <div>product.10@hari.ma</div>        | Employee | Product Manager · Product          | Active |
| <div>BZ</div> <div>Bilal Ziani</div> <div>lead.support@hari.ma</div>       | Manager  | Support Lead · Support             | Active |

## Inviting someone

The account and the employee record are created together, in one transaction, with **no password**. A one-time link is emailed; until it is used, the person cannot sign in.

This keeps HARI's oldest auth invariant intact. **Sign-in never creates an account** — even Google's callback rejects an unknown email. Provisioning is a server-side, permission-gated act, and the invite only opens a door to an account HR already made.

The screenshot shows the 'HARI HUMAN RESOURCES - AI' interface. On the left is a dark sidebar with a 'SUPER ADMIN WORKSPACE' menu including Dashboard, AI Assistant, Directory, People (highlighted), My Team, HR Activity, HR Analytics, Time Off, Onboarding, Offboarding, Documents, Knowledge Base, Alerts, Audit Log, and Settings. At the bottom of the sidebar is a user profile for 'Youssef Tazi Super Admin'. The main content area has a breadcrumb 'HARI / People / New' and a search bar. The title is 'Invite someone' with a subtitle 'Creates the account and emails a link to set a password. They can't sign in until they do.' The form contains fields for Name, Email, Role (set to 'Employee'), Employment type (set to 'full time'), Job title, Department, Location, Manager (set to 'No manager'), and Salary. A 'Send invite' button is at the bottom left of the form area.

The link reuses the machinery already behind password resets and magic links: only a SHA-256 hash is stored, it is single-use, and it is compared in constant time. The one difference is its life — seven days rather than thirty minutes, because the recipient is not sitting at their desk when HR provisions them, and a same-day expiry would just mean re-inviting everyone hired on a Friday.

Its screen is the reset screen with honest words: an invite says *Welcome — choose a password*, a reset says *you asked to change yours*. The kind travels with the form and the server narrows it to those two, so a **sign-in** secret — a magic link or an OTP — can never be spent on changing a password.

---

## What the server refuses

| You try to                              | It answers       | Because                                         |
|-----------------------------------------|------------------|-------------------------------------------------|
| Assign a role wider than your own       | escalation       | otherwise HR mints a Super Admin                |
| Change your own role                    | self_forbidden   | ask another admin; nobody promotes themselves   |
| Deactivate yourself                     | self_forbidden   | the same reason, and it locks you out           |
| Demote or disable the last active admin | would_lock_out   | /settings would have no key holder              |
| Set a salary you cannot read            | silently ignored | the field is omitted from the write, not zeroed |
| Make someone their own manager          | manager_cycle    | checked up the whole chain, not just one hop    |
| Reuse an email                          | email_taken      | it is the sign-in identity                      |

Two of those are worth expanding.

**Salary follows the read rule.** A caller without `salary:read:all` never sees the field and cannot set it. It is left out of the update entirely rather than written as zero — so someone who was never allowed to see a number cannot erase it either.

**The manager check walks the chain.** The org chart is self-referential and nothing else prevented a loop; an undetected one would hang every manager-scoped query in the app.

---

## Deactivating is not deleting

Two different acts, deliberately kept apart:

- **Deactivate** (`/people`) switches the **login** off. The person's record is untouched.
- **Offboard** (`/offboarding`) archives the **person** — status becomes `TERMINATED`, never a delete, because turnover analytics and historical payroll need them.

Deactivation takes effect immediately, which is a property of how HARI reads a session rather than anything the people admin does. Role and permissions are resolved from the database on **every request**, so a deactivated account is ejected on its next click — not whenever its token happens to expire. It is refused at every sign-in door too, and refused indistinguishably from a wrong password, so the form never reveals that the account exists.

The same mechanism is why a role change lands on the next click. There is no "sign out and back in for changes to take effect".

## Your own profile

Everyone has one, at `/profile`, reached from the account menu. You own your **display** — your name and your face:

**HARI**  
HUMAN RESOURCES · AI

EMPLOYEE WORKSPACE

- Dashboard
- AI Assistant
- Directory
- Time Off
- Onboarding
- Documents
- Knowledge Base

HARI / Your profile

Q Search... 96K

Employee

### Your profile

How you appear to your colleagues.

**Your profile**  
How you appear to your colleagues.

 [Add a photo](#)  
A square image works best. It's cropped to a circle and only visible to colleagues.

**Display name**  
Imane Chraibi

**Email**  
collaborateur@hari.ma  
You sign in with this.

[Save changes](#)

**Your role at work**  
HR keeps these up to date. Ask them if something looks wrong.

|           |                                |            |                  |
|-----------|--------------------------------|------------|------------------|
| Job title | Ingénieure Logiciel Full Stack | Department | IT               |
| Location  | Tétouan                        | Manager    | Karim El Idrissi |
| Started   | January 15, 2023               |            |                  |

 Imane Chraibi  
Employee

Everything under *Your role at work* is deliberately read-only. Letting people rewrite their own job title or manager would corrupt the org chart and every analytic built on it, so those stay HR's, on the same `/people` form. Email is read-only for a different reason: it is the sign-in identity and the key every auth token is issued against.

A photo is compressed in the browser, then re-encoded server-side to a square 512px WebP — so what is stored is always a clean raster, whatever was uploaded. Unlike the Knowledge Base cover images, which are decorative and served publicly behind an unguessable key, **an avatar requires a session to fetch**: a face is personal data under HARI's CNDP posture, and an unguessable URL is not the bar that deserves.

Replacing a photo deletes the old object, so changing it ten times leaves one file rather than ten.

Every mutation here is on the audit trail — `USER_INVITED`, `USER_UPDATED`, `USER_ROLE_CHANGED`, `USER_DEACTIVATED`, `USER_REACTIVATED`. A role change records `{ from, to }`, because a role slug is a code. The target's name and email are not, and never appear there.

The contract: <docs/architecture/authorization-invariants.md>. The sign-in flows: <docs/auth.md>.